

Aspectos Regulatórios (SOX, Acordos de Basiléia, ISO 27001; Data Protection Act (DPA): Legislação do Reino Unido; Marco Civil da Internet e General Data Protection Regulation (Lei Europeia e Brasileira)

Objetivo da Aula

Conhecer as principais leis e regulamentos que garantam os direitos fundamentais dos usuários. Conhecer e explorar os seguintes regulamentos/leis: SOX, Acordo de Basiléia, DPA, GDPR, LGPD e Marco Civil da internet.

Apresentação

Nesta aula de aspectos regulatórios em um mundo digital, vamos explorar regulamentações cruciais, que impactam o cenário empresarial e tecnológico atual. Nosso objetivo é fornecer o conhecimento necessário para navegar com confiança no mundo das leis e regulamentações que moldam a segurança de dados, a privacidade e a conformidade.

Começando com SOX, que molda as práticas de empresas públicas, passando pelos Acordos de Basiléia, que regulamentam instituições financeiras; reiterando a ISO 27001, para segurança de informação; a DPA, do Reino Unido; o Marco Civil da Internet brasileira; e o impactante Regulamento GDPR europeu e sua contraparte brasileira.

1. Desvendando o Cenário Empresarial Regulatório

Esta nossa jornada começa com a compreensão fundamental dos aspectos regulatórios. Estes são os pilares que sustentam o funcionamento do mundo dos negócios e da tecnologia. São as regras do jogo, as diretrizes que todas as organizações, grandes ou pequenas, públicas ou privadas, precisam seguir. Mas por que isso é tão importante?

Imagine os aspectos regulatórios como um conjunto de regras que garantem a segurança, integridade e transparência nos negócios. Eles são projetados para proteger não apenas os interesses das empresas, mas também os direitos e interesses de todas as partes envolvidas, desde clientes e funcionários até investidores e a sociedade em geral. Em essência, eles são a espinha dorsal da confiança em nossas transações e interações digitais. Confira o objetivo destas regulamentações abaixo:

- **Promover a conformidade legal:**

- Garantir que as empresas operem conforme as leis e regulamentos aplicáveis, evitando atividades ilegais, práticas antiéticas e fraudes.

- **Proteger interesses diversos:**

- Os aspectos regulatórios visam proteger os interesses de todas as partes envolvidas, incluindo clientes, funcionários, acionistas, investidores e a sociedade em geral (quando aplicável).

- **Garantir a segurança da informação:**

- Estabelecer padrões de segurança e integridade para proteger dados, informações financeiras e outros ativos críticos;
- É necessário sempre levar em consideração o objetivo principal de segurança da informação:
 - Garantir e proteger a confidencialidade, integridade e disponibilidade de ativos de informação.

- **Promover a concorrência justa:**

- Evitar práticas monopolistas, que garantam que a concorrência no mercado seja justa e benéfica para os consumidores.

- **Gerenciar riscos financeiros:**

- Estabelecer diretrizes para instituições financeiras para garantir a estabilidade do sistema financeiro e a proteção dos depositantes.

- **Promover a transparência e a prestação de contas:**

- Exigir que empresas divulguem informações financeiras e operacionais de forma transparente, de modo que os *stakeholders* possam avaliar sua saúde financeira e responsabilidade relativa.

A compreensão destes aspectos regulatórios é fundamental porque eles desempenham um papel crucial na governança e na conformidade das empresas, impactando diretamente suas operações, estratégias de negócios e relacionamentos com as partes interessadas/*stakeholders*. O não cumprimento das regulamentações pode resultar em sanções legais, danos à reputação e impactos financeiros negativos. Portanto, é essencial que as empresas e profissionais estejam cientes dessas regulamentações e se esforcem para cumpri-las eficazmente.

2. Lei Sarbanes-Oxley (SOX)

Assinada pelo senador Paul Sarbanes e o deputado Michael Oxley, a Lei Sarbanes-Oxley, ou SOX, entrou em vigor em julho de 2002, durante o governo do presidente George W. Bush, nos Estados Unidos. Considerado uma das regulamentações mais rigorosas, esta lei trata de controles internos junto de elaboração de relatórios financeiros e divulgações deles.

Estas regulamentações rigorosas se fizeram necessárias após uma série de escândalos no começo dos anos 2000, que envolveram dívidas bilionárias de empresas como Xerox e Enron. Estes escândalos forçaram a mão dos Estados Unidos a tomar ações concretas, como a criação de um mecanismo que conseguisse transmitir confiança e assegurar a responsabilidade corporativa das organizações com seus investidores e acionistas.



Você Sabia?

Essa série de escândalos foram vários esquemas de fraudes descobertos em várias empresas. Devido à “maquiagem” de gastos e lucros, empresas como a Enron acumularam mais de 60 bilhões de dívidas, incluindo dívidas aos funcionários e acionistas da empresa. Porém, não só a Enron caiu nessa situação, mas também a Worldcom, AOL Time Warner, Xerox, Merck, Bristol-Myers Squibb, Citigroup, JP Morgan e Chase. Note que são empresas de várias áreas de atuação, como financeiras, farmacêuticas, tecnologia da informação, e por aí vai. Todas com dívidas milionárias, e em alguns casos, bilionárias, causando dano irreparável à confiança nestas marcas americanas.

Todas as empresas, sejam americanas ou não, com ações na SEC (Agência Federal dos Estados Unidos que regula os mercados financeiros e protege os investidores, equivalente à Comissão de Valores Mobiliários aqui no Brasil), devem seguir as definições da SOX. Com

o intuito de garantir a transparência na gestão empresarial, a SOX não é um conjunto de processos e práticas a serem seguidos, porém uma lista, que define que registros devem ser armazenados e disponíveis por quanto tempo.

Bem, isso significa que não apenas o setor financeiro age em cima deste regulamento, mas também o de TI, pois deve armazenar os registros eletrônicos de forma segura. Registros comerciais, registros eletrônicos e mensagens eletrônicas devem ser guardadas por pelo menos cinco anos, por exemplo. As consequências variam de acordo com o impacto do não cumprimento da regulamentação, podendo ir de variadas multas até a mandados de prisão.

2.1. Destaques da SOX

Contando com 69 artigos, a SOX define medidas de boas práticas de governança e segurança, forçando as organizações a estruturarem seus processos, envolvendo checagens de transparência e auditorias minuciosas. Dentre todos seus artigos e seções, destaco aqui alguns pontos:

- **Seção 302:**
 - Requer a participação ativa da alta administração, para que consigam certificar e aprovar a precisão das demonstrações financeiras, assim como a eficácia dos controles internos de divulgação.
- **Seção 401:**
 - Estabelece que as demonstrações financeiras publicadas pelos emissores devem ser precisas e apresentadas para evitar declarações incorretas. Isso inclui a divulgação de todos os passivos, obrigações e transações relevantes.
- **Seção 404:**
 - Exige que os emissores divulguem informações em seus relatórios anuais sobre a estrutura e eficácia dos controles internos e procedimentos de relatórios financeiros.
- **Seção 409:**
 - Obriga os emissores a divulgarem ao público, de forma rápida e compreensível, informação sobre mudanças substanciais em sua condição financeira ou operações, apoiadas por tendências e informações qualitativas.
- **Seção 802:**
 - Impõe penalidades severas, incluindo multas e prisão, para alteração, destruição, ocultação ou falsificação de registros, com a intenção de construir investigações

legais, bem como para a violação dos requisitos de manutenção de documentos de auditoria.

- **Seção 906:**

- Aborda penalidades criminais para a certificação de relatórios financeiros enganosos ou fraudulentos, com multas substanciais e possibilidades de prisão.

Estas seções, combinadas, estabelecem um sistema rigoroso de supervisão, responsabilidade e punição, para garantir que as empresas públicas atendam aos mais altos padrões de relatórios financeiros e transparência. Isto tem o objetivo de proteger investidores e a integridade dos mercados financeiros.

2.2. Vantagens e Desvantagens da SOX

Considerando o rigoroso controle sobre registros impostos pela SOX, é natural surgirem algumas desvantagens no processo. Primeiramente, a SOX, embora estabeleça regras rígidas, não fornece diretrizes específicas sobre como implementar o sistema que requer. Isto implica que cada empresa deve encontrar sua própria maneira de atender a essas exigências. Correndo o risco de sofrer as consequências, caso cometa erros no processo. Além disso, a preparação de relatórios e auditorias internas acarreta custos adicionais para as empresas, exigindo ajustes em seus orçamentos.

No entanto, as desvantagens não são a história completa: na verdade, a SOX oferece mais vantagens do que desvantagens, quando implementada corretamente, especialmente em termos de promoção da concorrência justa e proteção do consumidor final. A responsabilidade das empresas por suas próprias ações significa que os acionistas podem tomar decisões bem fundamentadas com base em informações transparentes sobre as operações internas da empresa, ajudando a evitar práticas fraudulentas.

Em conformidade com os rigorosos padrões das SOX, houve notável aprimoramento nos controles internos, traduzido em resultados mais precisos, proporcionando um planejamento mais sólido. Uma vez que a alta administração e seus executivos se tornam responsáveis por quaisquer ações fraudulentas dentro da empresa, isso contribui para restaurar a confiança abalada devido a escândalos passados. Todos esses elementos se unem para criar uma camada de proteção, que permite aos acionistas investirem com conhecimento, baseando suas decisões na transparência e na integridade do mercado.

3. Acordo de Basiléia

No mundo moderno de hoje, impulsionado pela globalização, a comunicação instantânea e a interconectividade tornaram-se a norma. No entanto, esta integração global não é exclusiva das comunicações; ela também moldou o sistema financeiro em uma superestrutura global. Para garantir essa integração e estabilidade financeira, surgiram regras e limites que padronizam as operações de bancos e instituições financeiras. A peça central dessas medidas é o Acordo de Basiléia.

O Acordo de Basiléia estabelece parâmetros essenciais de liquidez e responsabilidade para o mercado financeiro, reduzindo os riscos nas operações de crédito e garantindo a estabilidade do sistema financeiro como um todo. Originado em 1988, o acordo passou por evoluções e atualizações, com o Comitê de Basiléia se reunindo em duas ocasiões posteriores para aprimorar o acordo, resultando nos documentos dos Acordos de Basiléia I, Basiléia II e Basiléia III.

3.1. Regras Principais dos Três Acordos

Todos esses acordos compartilham dois objetivos principais: estabelecer e implementar uma metodologia comum para a avaliação de riscos em operações financeiras e exigir que as instituições mantenham um índice mínimo de capital em reserva.

O acordo inicial, Basiléia I, estabelece três regras fundamentais, que sustentam todo o pacto:

- Determina que os bancos devem manter, no mínimo, 8% do valor total de seus empréstimos em reserva;
- Estabelece que as instituições devem manter o capital próprio em reserva para mitigar possíveis riscos;
- Exige que todas as instituições avaliem o risco de suas operações de empréstimo e financiamento, com base na análise do perfil de crédito do tomador de empréstimos.

Já o Basiléia II, idealizado em 2004, adota uma abordagem mais subjetiva. Seu principal objetivo é fortalecer as medidas estabelecidas no acordo anterior, permitindo, no entanto, maior flexibilidade aos bancos centrais nacionais.

Por fim, o Basiléia III, assinado em 2010 como uma resposta à crise financeira de 2008, expande as regras dos acordos anteriores. Com a introdução de limites mais rígidos, há um

controle maior dentro destas empresas. Isto pode ser mais bem exemplificado nestas duas medidas, explicitadas abaixo, deste acordo:

- **Conservação de capital:**
 - Além dos 8% estipulados no acordo inicial, as instituições devem manter uma reserva adicional de 2,5%, elevando o percentual total de capital a ser mantido para 10,5%.
- **Colchão contracíclico de capital:**
 - Além do índice mínimo, esta regra determina que as instituições mantenham uma reserva de 2,5% sobre o capital emprestado, variando de acordo com a economia de cada país. Essa reserva visa mitigar o risco de uma crise sistêmica.

Estes acordos de Basileia, em sua evolução ao longo do tempo, desempenham um papel vital na regulamentação bancária global e na promoção da estabilidade financeira em escala internacional.

4. Data Protection Act

A lei de proteção de dados no Reino Unido (**Data Protection Act**, DPA) é um marco regulatório, que desempenha um papel essencial na proteção de dados pessoais no contexto britânico. Ela é a implementação britânica da GDPR, a lei de proteção de dados europeia, formulado após o Brexit, a retirada do Reino Unido da União Europeia.

A DPA 2018 controla como a informação pessoal é utilizada por organizações, empresas ou até mesmo pelo governo. Todos os responsáveis por utilizar dados pessoais têm de seguir uma série de regras estritas, chamadas de “princípios de proteção de dados”. A DPA garante que os dados pessoais serão:

- Usados de forma justa, legal e transparente;
- Utilizadas para fins específicos e explícitos;
- Manipuladas de maneira adequada, relevante e restrita apenas ao necessário;
- Precisas e, quando necessário, atualizadas;
- Mantidas pelo tempo estritamente necessário;
- Tratamento de forma a garantir a segurança apropriada, incluindo proteção contra processamento ilegal ou não autorizado, acesso não autorizado, perda, destruição ou danos.

As informações abaixo, mais sensíveis, possuem proteção legal mais rigorosa, também garantida pela DPA:

- Raça;
- Origem étnica;
- Opiniões políticas;
- Crenças religiosas;
- Filiação a sindicatos;
- Genética;
- Biometria (quando usada para identificação);
- Saúde;
- Vida sexual ou orientação sexual.

De acordo com a lei, o cidadão tem o direito de saber quais informações o governo e outras organizações têm sobre ele. Isso inclui o direito de: ser informado sobre como seus dados estão sendo usados; acessar dados pessoais; atualizar dados incorretos; excluir dados; parar ou restringir o processamento de seus dados; portabilidade de dados; se opor ao processamento de seus dados em determinadas circunstâncias. O cidadão também goza do direito quando uma organização está usando seus dados pessoais para: processos de tomada de decisão automatizada ou montagens de perfil para prever comportamentos ou interesses.

5. GDPR e LGPD

GDPR é o Regulamento Geral de Proteção de Dados da União Europeia, que entrou em vigor em 2018. Sua principal finalidade é fortalecer e unificar a proteção de dados pessoais dentro da União Europeia e garantir que os indivíduos tenham maior controle sobre suas informações pessoais. O GDPR se aplica a todas as organizações que processam dados pessoais de residentes da União Europeia, independentemente de a organização estar sediada na UE ou em qualquer outro lugar do mundo. Isso significa que a regulamentação tem um escopo global e afeta empresas e entidades que tratam dados de cidadãos europeus.

Já a LGPD, ou a Lei Geral de Proteção de Dados Pessoais, é a legislação brasileira que entrou em vigor em 2020. Seu principal objetivo é regulamentar o tratamento de dados

peçoais no Brasil, bem como as organizações localizadas fora do país, que tratam dados de residentes brasileiros. Portanto, a LGPD tem um alcance nacional e internacional.

Repare como as duas são parecidas e como ambas também possuem semelhanças com a DPA britânica. Isso não é por acaso, a GDPR serviu como base para a criação tanto da DPA quanto da LGPD. As três possuem os mesmos objetivos, proteção de dados pessoais de sua população, porém atuam de forma adaptada a sua região. A principal diferença entre elas é a jurisdição de cada uma, sendo a DPA aplicada no Reino Unido, GDPR na União Europeia e a LGPD no Brasil.

As três garantem aos titulares de dados diversos direitos, como: direito à informação própria; direito de acesso; direito de correção; direito de exclusão; direito de oposição; direito de portabilidade de dados. Estes regulamentos também forçam as organizações a garantirem algumas responsabilidades, tais como: nomeação de encarregado de proteção de dados; registro de atividades de processamento; avaliação de impacto à proteção de dados; e notificação de violação de dados.

A não conformidade dos direitos e responsabilidades podem acarretar sanções rigorosas em todos estes regulamentos. Na LGPD, as multas podem chegar a 2% do faturamento anual da organização, limitado a 50 milhões de reais por infração. Além disso, a autoridade nacional de proteção de dados pode impor medidas corretivas, como a suspensão do processamento de dados ou a proibição do tratamento de dados específicos.

A LGPD tem como objetivo fortalecer a proteção de dados pessoais no Brasil, garantindo que as organizações respeitem os direitos dos titulares de dados e implementem medidas de segurança adequadas. Ela reflete a preocupação do país em alinhar suas práticas de proteção de dados com os padrões internacionais e garantir a privacidade e segurança dos indivíduos.

6. Marco Civil da Internet

O Marco Civil da Internet, oficialmente conhecido como Lei n. 12.965/2014, é uma legislação brasileira que estabelece princípios, direitos e deveres para o uso da internet no país. Sua origem remonta ao processo de consulta pública sobre a regulamentação da internet no Brasil, que ocorreu entre 2009 e 2010. A consulta envolveu uma ampla gama de partes interessadas, incluindo a sociedade civil, empresas de tecnologia, acadêmicos e o governo.

Por meio de várias sessões deliberativas, audiências públicas e muita discussão, o marco foi assinado e entrou em vigor em 2014, concedendo direitos ao usuário de internet no Brasil. No mesmo período, se discutia um regulamento chamado de ACTA, na União Europeia, que restringia muito a liberdade na internet e acabou sendo rejeitado pela UE. O Marco Civil é considerado uma das leis mais progressistas do mundo em relação à governança da internet e tem influenciado outras nações em seus esforços para estabelecer diretrizes similares.

Como outros regulamentos de governança de dados, o Marco Civil estabelece uma série de princípios e direitos para os usuários da internet no Brasil:

- **Neutralidade da Rede:**

- Um dos princípios mais notáveis é a neutralidade da rede, que garante que os provedores de internet tratem todos os dados igualmente sem discriminação de conteúdo, aplicativos ou serviços.

- **Privacidade e Proteção de Dados:**

- A legislação garante a proteção da privacidade dos usuários e exige que os provedores de serviço de internet respeitem a confidencialidade dos dados pessoais.

- **Liberdade de Expressão e Informação:**

- O Marco Civil assegura a liberdade de expressão e proíbe a censura prévia na internet, permitindo que os usuários expressem suas opiniões livremente.

- **Responsabilidade por Conteúdo:**

- A lei estabelece que os provedores de serviços de internet não podem ser responsabilizados pelo conteúdo gerado por terceiros, a menos que não cumpram uma ordem judicial específica.

- **Acesso Universal:**

- O Marco Civil promove o acesso universal à internet como um direito fundamental, incentivando a expansão da infraestrutura de telecomunicações.

Os provedores de serviço de internet no Brasil têm a responsabilidade de cumprir com as disposições do Marco Civil, incluindo a proteção dos usuários, a manutenção da neutralidade da rede e o cumprimento de ordens judiciais. Eles também devem manter registros de conexão, de acordo com a legislação, para fins de investigação criminal.

O Marco Civil da Internet no Brasil tem sido fundamental para estabelecer um ambiente digital que protege os direitos dos usuários e promove a liberdade na internet.

Ele desempenhou um papel importante na criação de um ambiente digital democrático e aberto, e seu impacto transcende as fronteiras do país, influenciando discussões sobre regulamentação da internet em todo o mundo.

Considerações Finais da Aula

Nesta aula, exploramos aspectos regulatórios cruciais, que desempenham um papel fundamental no mundo dos negócios e na tecnologia. Essas regulamentações são projetadas para garantir segurança, integridade e transparência nas operações comerciais e proteger os interesses de várias partes interessadas.

As regulamentações são as regras do jogo que todas as organizações, independentemente do tamanho ou natureza, devem seguir para promover a conformidade legal e a concorrência justa e responsável baseada em gestão de riscos.

SOX, Acordo de Basiléia, DPA, GDPR, LGPD e Marco Civil da Internet são todos regulamentos ou leis que garantem direitos aos usuários e responsabilizam as organizações que lidam com estes usuários. Em conjunto, são capazes de montar uma superestrutura internacional que consegue se comunicar de forma segura e controlada, porém garantindo direitos fundamentais.

Materiais Complementares



Marco Civil da Internet

2014, Brasil.

Lei n. 12.965, que estabelece princípios, garantias, direitos e deveres para o uso da Internet no Brasil.

Disponível em: https://www.planalto.gov.br/ccivil_03/_ato2011-2014/2014/lei/l12965.htm. Acesso em: 26 jan. 2024.



LGPD

2018, Brasil.

Lei n. 13.709, que estabelece a Lei Geral de Proteção de Dados Pessoais (LGPD) no Brasil.

Disponível em: https://www.planalto.gov.br/ccivil_03/_ato2015-2018/2018/lei/l13709.htm. Acesso em: 26 jan. 2024.

Referências

CARTILHA de Segurança para Internet. **CERT.br**, 2024. Disponível em: <https://cartilha.cert.br/>. Acesso em: 1º ago. 2023.